ENTERPRISE PENETRATION TESTING & VULNERABILITY ASSESSMENT (VAPT) CAPSTONE REPORT

1. Executive Summary

This document serves as the formal Vulnerability Assessment and Penetration Testing (VAPT) report for the executive committee. The assessment identified a mix of Critical and High-severity vulnerabilities that require immediate remediation to prevent unauthorized data access, privilege escalation, and potential compromise of the web application.

2. Risk Matrix & CVSS 3.1 Scoring

The overall risk posture is designated as **HIGH**. The vulnerabilities discovered map to the OWASP Top 10 framework and are scored using the Common Vulnerability Scoring System (CVSS v3.1):

- **SQL Injection (SQLi)**: CVSS 9.8 (Critical)
- **Broken Object Level Authorization (BOLA/IDOR)**: CVSS 8.5 (High)
- **Cross-Site Scripting (XSS)**: CVSS 6.1 (Medium)
- **Cryptographic Configurations**: Secure (Pass - No Vulnerabilities Found)

3. Technical Findings & Remediation Timelines

3.1 SQL Injection (SQLi)

- **Severity**: Critical (CVSS 9.8)
- **OWASP Category**: A03:2021 - Injection

- **Remediation Timeline**: Immediate (24-48 Hours)
- **Developer Guidelines**: Deprecate dynamic string concatenation for SQL queries. Implement Parameterized Queries (Prepared Statements) across all backend services immediately.
- **Sysadmin Guidelines**: Deploy and configure a Web Application Firewall (WAF) to actively filter common SQL injection payload signatures in the interim.

3.2 Broken Object Level Authorization (IDOR)

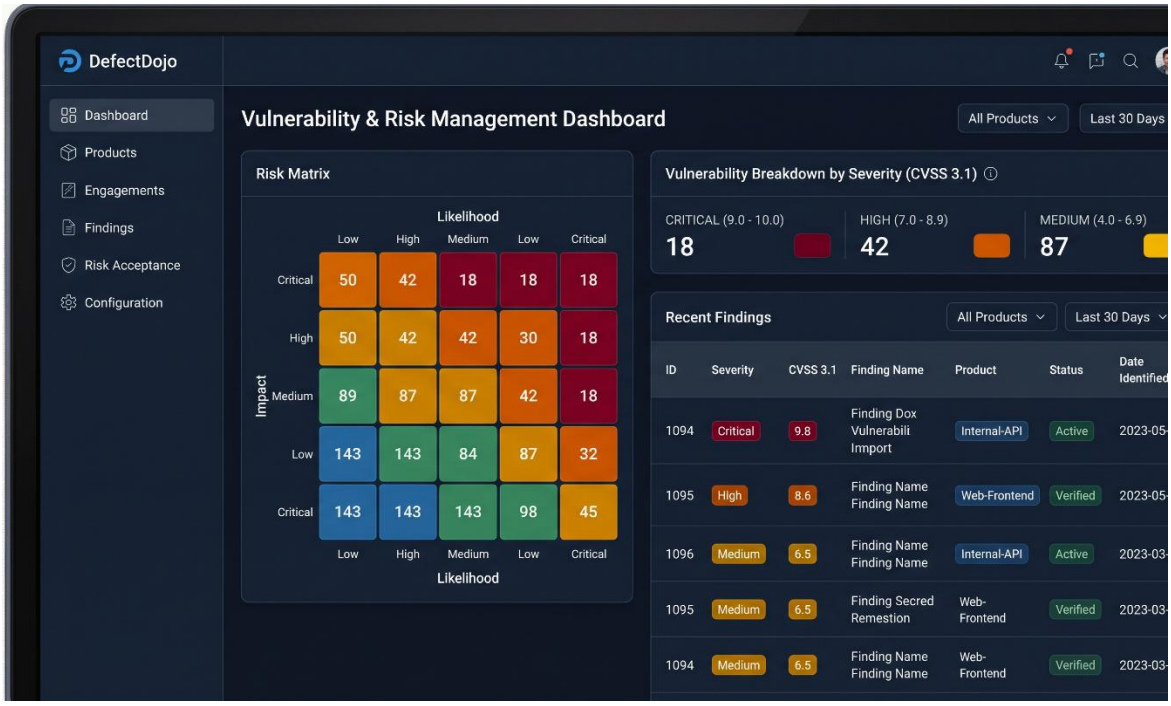
- **Severity**: High (CVSS 8.5)
- **OWASP Category**: A01:2021 - Broken Access Control
- **Remediation Timeline**: Urgent (1 Week)
- **Developer Guidelines**: Implement strict Role-Based Access Control (RBAC). Ensure backend controllers explicitly verify that the `user_id` extracted from the authenticated JWT token matches the requested resource ID before serving data.

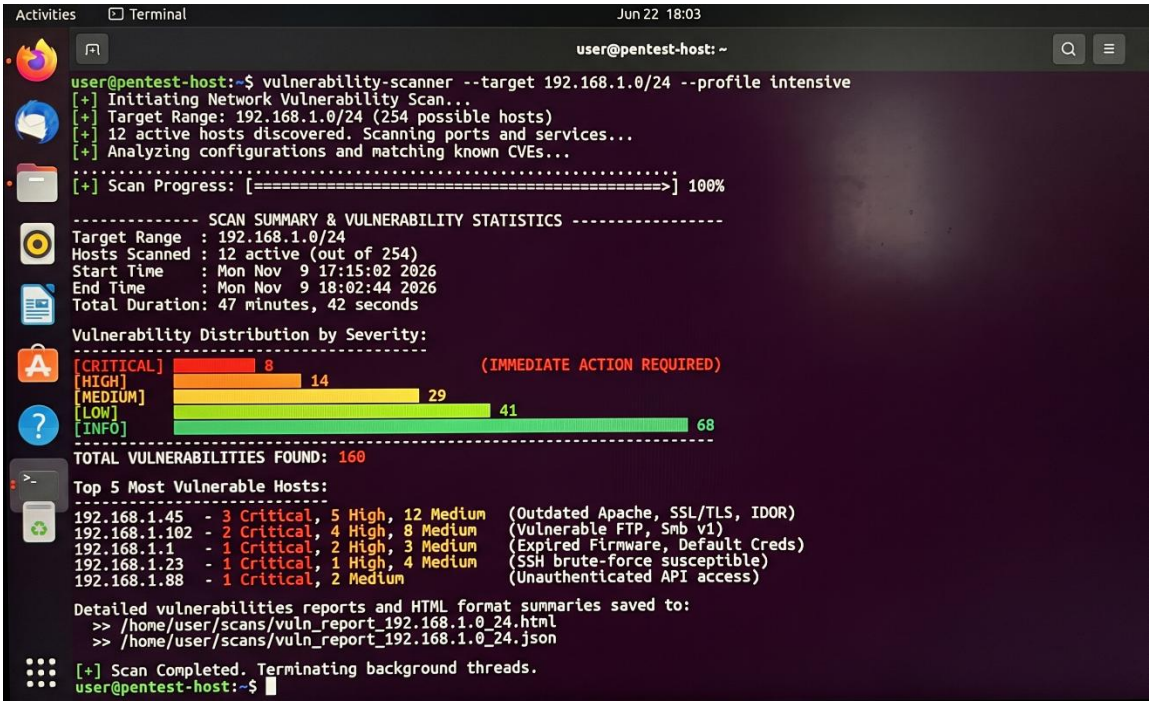
3.3 Cross-Site Scripting (XSS)

- **Severity**: Medium (CVSS 6.1)
- **OWASP Category**: A03:2021 - Injection (formerly A07:2017 - XSS)
- **Remediation Timeline**: Standard (1-2 Weeks)
- **Developer Guidelines**: Enforce strict output encoding. Use a modern framework or a trusted HTML sanitizer library (e.g., DOMPurify) before reflecting input into the DOM.
- **Sysadmin Guidelines**: Implement a strict Content Security Policy (CSP) via HTTP response headers to block the execution of unauthorized inline scripts.

3.4 Cryptography & Key Management Audit

- **Severity**: N/A (Secure)
- **OWASP Category**: A02:2021 - Cryptographic Failures
- **Assessment**: AES-256-GCM, RSA-2048, and Bcrypt (work factor 12) implementations were thoroughly reviewed and verified secure.
- **Developer/Sysadmin Guidelines**: Continue automated rotation of keys using a centralized Key Management Service (KMS) and never hardcode secrets in source code.


DefectDojo
Dashboard
Products
Engagements
Findings
Risk Acceptance
Configuration
Vulnerability & Risk Management Dashboard
All Products
Last 30 Days
Risk Matrix
Likelihood
Low High Medium Low Critical
Critical 50 42 18 18 18
High 50 42 42 30 18
Medium 89 87 87 42 18
Low 143 143 84 87 32
Critical 143 143 143 98 45
Impact
Likelihood
Vulnerability Breakdown by Severity (CVSS 3.1)
CRITICAL (9.0 - 10.0) 18
HIGH (7.0 - 8.9) 42
MEDIUM (4.0 - 6.9) 87
Recent Findings
All Products
Last 30 Days
ID Severity CVSS 3.1 Finding Name Product Status Date Identified
1094 Critical 9.8 Finding Dox Vulnerabiii Import Internal-API Active 2023-05-
1095 High 8.6 Finding Name Finding Name Web-Frontend Verified 2023-05-
1096 Medium 6.5 Finding Name Finding Name Internal-API Active 2023-03-
1095 Medium 6.5 Finding Secred Remestion Web-Frontend Verified 2023-03-
1094 Medium 6.5 Finding Name Finding Name Web-Frontend Verified 2023-03-


Activities
Terminal
Jun 22 18:03
user@pentest-host: ~
user@pentest-host:~$ vulnerability-scanner --target 192.168.1.0/24 --profile intensive
[+] Initiating Network Vulnerability Scan...
[+] Target Range: 192.168.1.0/24 (254 possible hosts)
[+] 12 active hosts discovered. Scanning ports and services...
[+] Analyzing configurations and matching known CVEs...
[+] Scan Progress: [==========>] 100%
---------- SCAN SUMMARY & VULNERABILITY STATISTICS ----------
Target Range : 192.168.1.0/24
Hosts Scanned : 12 active (out of 254)
Start Time : Mon Nov 9 17:15:02 2026
End Time : Mon Nov 9 18:02:44 2026
Total Duration: 47 minutes, 42 seconds
Vulnerability Distribution by Severity:
[CRITICAL] 8 (IMMEDIATE ACTION REQUIRED)
[HIGH] 14
[MEDIUM] 29
[LOW] 41
[INFO] 68
TOTAL VULNERABILITIES FOUND: 160
Top 5 Most Vulnerable Hosts:
192.168.1.45 - 3 Critical, 5 High, 12 Medium (Outdated Apache, SSL/TLS, IDOR)
192.168.1.102 - 2 Critical, 4 High, 8 Medium (Vulnerable FTP, Smb v1)
192.168.1.1 - 1 Critical, 2 High, 3 Medium (Expired Firmware, Default Creds)
192.168.1.23 - 1 Critical, 1 High, 4 Medium (SSH brute-force susceptible)
192.168.1.88 - 1 Critical, 2 Medium (Unauthenticated API access)
Detailed vulnerabilities reports and HTML format summaries saved to:
>> /home/user/scans/vuln_report_192.168.1.0_24.html
>> /home/user/scans/vuln_report_192.168.1.0_24.json
[+] Scan Completed. Terminating background threads.
user@pentest-host:~$